

Data Retention and Disposal Policy — My Cash Pilot

Owner: Bryan Pham, CEO · Security contact: info@ahnmedia.com Version 1.0 · Effective 16 September 2026 · Next review 16 March 2027

This policy states how long My Cash Pilot keeps each kind of data, why, and how that data is disposed of. It is a companion to the Information Security Policy and expands its section 4. It is reviewed every six months and whenever a new data source is connected.

My Cash Pilot is an internal system operated by AHN Media for its own company accounts. The financial data it holds is the company's own accounting record. There are no outside consumers and no customer data of third parties.

1. Principles

1. **Keep what the books require, and no more.** Accounting records are kept for the period tax and corporate law require. Everything else is kept only as long as it serves the purpose it was collected for.
2. **Credentials are not records.** A banking credential has no archival value. It is destroyed the moment the connection it belongs to ends.
3. **Do not collect what need not be kept.** Bank login details never reach this system; imported screenshots are read and discarded rather than stored.
4. **Disposal is deletion, not concealment.** Data removed under this policy is deleted from the live database; it then ages out of encrypted backups within the provider's recovery window.

2. What is held, how long, and how it is disposed of

Data	Retention	Disposal
Bank and card transactions from Plaid (date, amount, currency, merchant, category, account)	7 years after the end of the financial year, or longer where local law requires — Vietnamese accounting law requires 10 years for accounting documents	Deleted from the database at the end of the period
Account records — name, type, mask, balances	While the account is connected, then for the retention period of the transactions it carries	Deleted with its transactions
Plaid access tokens	Only while the connection is active	Deleted on disconnect, in the same request that removes the Item at Plaid
QuickBooks and Stripe tokens	Only while the connection is active	Deleted on disconnect, after the grant is revoked at the provider
Bank screenshots imported by staff	Not retained at all — read in memory and discarded	Never written to disk or database; only the reviewed rows are stored
Import records — which file, which account, who imported, row counts	With the transactions they produced	Deleted with them
Audit log — permission changes, connections, disconnections, imports	7 years, matching the financial records it explains	Deleted at the end of the period
Provider error records — time, provider, operation, the provider's own error identifiers	90 days	Deleted on a rolling basis
Application and access logs held by the hosting platform	The platform's own retention window, currently up to 30 days	Expire automatically at the platform
User accounts and authenticator factors	While the person has access	Deleted on the person's last day, or on request
Database backups	The managed provider's point-in-time recovery window	Expire automatically; deleted data ages out of backups within that window

3. Disconnection — what happens to Plaid data

When a connection is disconnected from the Integrations page, in this order:

1. **The Item is removed at Plaid** (`/item/remove`), which invalidates the access token at Plaid and ends the connection to the bank. This is done first, so that a failure leaves the connection in place to be retried rather than stranding a live permission we can no longer reach.
2. **The stored credentials are deleted here** — access token, refresh token, expiry and sync cursor are all set to null.
3. **The disconnection is written to the audit log** with who did it, when, and what happened at the provider.

Transactions already imported are not deleted by a disconnection. They are the company's own accounting records, and deleting them would destroy the books. To delete them as well, the retention period in section 2 applies, or an explicit deletion request under section 4.

4. Deletion requests

Because the data is AHN Media's own business record, the parties who may request deletion are the company itself and the individuals who hold accounts:

- **An individual's account** — the account, its authenticator factor and its personal details are deleted within 30 days of the request. Actions that person took remain in the audit log, which is the point of an audit log.
- **A connected account's data** — on request, all transactions and balances imported from that account are deleted, subject to any legal obligation to retain accounting records for the periods in section 2.
- **Requests** go to info@ahnmedia.com and are actioned by the security owner.

Where a retention obligation prevents immediate deletion, the requester is told which obligation applies and when the data will be deleted.

5. Where the data lives

All financial data is held in a single managed PostgreSQL database (Supabase), encrypted at rest by the provider with AES-256, with row-level security on every table. Provider access tokens carry a second layer: they are encrypted by the application with AES-256-GCM before they are written, using a key held only in server environment variables.

Data is not copied to spreadsheets, local databases or third-party analytics tools as a matter of routine. No Plaid data is sent to any AI service.

6. Enforcement and review

The security owner is responsible for this policy. At each six-month review:

1. data past its retention period is identified and deleted;
2. disconnected connections are confirmed to hold no credentials;
3. error records older than 90 days are confirmed to be gone;
4. any deletion request received since the last review is confirmed to have been actioned;
5. the review, and anything changed, is recorded below.

Review log

Date	Version	Reviewer	Change
16 Sep 2026	1.0	Bryan Pham, CEO	First issue